

VAPT Final Report

CoreTech Innovation - Vulnerability Assessment & Penetration Testing

Project ID: VAPT-2026-CTI-001 **Date:** June 15-27, 2026 **Classification:** CONFIDENTIAL

Table of Contents

1. Executive Summary
 2. Scope and Methodology
 3. Findings
 4. Risk Ratings
 5. Recommendations
 6. Appendix
-

Executive Summary

CoreTech Innovation ke network infrastructure (192.168.1.0/24) par 14-day comprehensive VAPT assessment conduct kiya gaya. Testing ke dauraan 26 vulnerabilities identify hui, jinmein 3 critical, 5 high, 8 medium, 4 low, aur 6 informational hain.

Sabse critical finding BlueKeep (CVE-2019-0708) vulnerability hai jo Domain Controller (192.168.1.30) par remote code execution allow karti hai. Is vulnerability ka exploit karke humne full SYSTEM access aur domain compromise achieve kiya.

Scope and Methodology

Testing Scope

- **Network Range:** 192.168.1.0/24
- **Hosts:** 6 active hosts discovered
- **Services:** 15 services identified
- **Duration:** 14 days
- **Methodology:** PTES Standard

Testing Phases

Phase 1: Pre-Engagement (Day 1)

- Rules of Engagement (RoE) signed
- Testing windows defined (off-business hours)
- Emergency contacts established
- Scope boundaries defined

Phase 2: Intelligence Gathering (Days 2-3)

- **Passive Reconnaissance:**
 - OSINT via Shodan, Censys

- DNS enumeration (dnsrecon)
- Social media analysis
- **Active Reconnaissance:**
 - Ping sweep: 256 IPs scanned
 - ARP scan for local discovery
 - Full TCP port scan (1-65535)
 - Service version detection
 - OS fingerprinting

Results:

- 6 active hosts discovered
- 23 open ports identified
- 15 services fingerprinted

Phase 3: Threat Modeling (Day 4)

- **High-Value Targets:**
 - Domain Controller (192.168.1.30)
 - Database Server (192.168.1.20)
 - Web Server (192.168.1.10)
- **Attack Vectors:**
 - External -> DMZ -> Internal
 - RDP exploitation
 - SMB exploitation
 - Database compromise

Phase 4: Vulnerability Analysis (Days 5-7)

- **Automated Scanning:**
 - Nessus Professional: 26 vulnerabilities
 - OpenVAS: 18 vulnerabilities
 - Nmap NSE scripts: 12 vulnerabilities
- **Manual Verification:**
 - False positive elimination
 - Vulnerability chaining analysis
 - Business context assessment

Phase 5: Exploitation (Days 8-10)

- **BlueKeep Exploitation:**
 - Target: 192.168.1.30:3389
 - Tool: Metasploit Framework
 - Result: SYSTEM access achieved
- **MySQL Exploitation:**
 - Target: 192.168.1.20:3306
 - Method: Empty root password
 - Result: Full database access
- **SMB Exploitation:**

- Target: 192.168.1.30:445
- CVE: CVE-2020-0796
- Result: Remote code execution

Phase 6: Post-Exploitation (Days 11-12)

- **Privilege Escalation:**
 - SYSTEM access on Domain Controller
 - NTLM hash dumping
 - Pass-the-Hash attacks
- **Lateral Movement:**
 - DB server compromise
 - Credential harvesting
 - Network reconnaissance
- **Impact Assessment:**
 - 2,847 user accounts exposed
 - Payment database accessible
 - Full domain control achieved

Phase 7: Reporting (Days 13-14)

- Executive summary for leadership
- Technical findings for IT team
- Remediation roadmap
- Retest recommendations

Findings

Finding 1: BlueKeep Remote Code Execution (CVE-2019-0708)

Severity: CRITICAL **CVSS Score:** 9.8 **Host:** 192.168.1.30 **Port:** 3389/tcp **Service:** Microsoft Terminal Services

Description: Domain Controller par Windows Server 2019 Build 17763 BlueKeep vulnerability ke liye susceptible hai. Ye vulnerability RDP (Remote Desktop Protocol) mein remote code execution allow karti hai bina authentication ke.

Evidence:

```
Nmap NSE Script:
| rdp-vuln-ms12-020:
|   VULNERABLE:
|     MS12-020 Remote Desktop Protocol Vulnerability
|       State: VULNERABLE
|_    Risk factor: Critical  CVSSv2: 9.8 (CRITICAL)
```

Exploitation:

```
Metasploit: exploit/windows/rdp/cve_2019_0708_bluekeep_rce
Result: Meterpreter session established
Privilege: NT AUTHORITY\SYSTEM
```

Impact:

- Complete domain controller compromise
- All Active Directory hashes dumped
- 12 logged-on user sessions accessible
- Potential for ransomware deployment
- Lateral movement to all domain-joined systems

Affected Systems:

- Domain Controller (192.168.1.30)
 - All domain-joined workstations
-

Finding 2: MySQL Empty Root Password (CVE-2021-2144)

Severity: CRITICAL **CVSS Score:** 9.1 **Host:** 192.168.1.20 **Port:** 3306/tcp **Service:** MySQL 5.7.32

Description: Database server par MySQL root account ke liye koi password set nahi hai. Isse koi bhi attacker database ko access kar sakta hai bina authentication ke.

Evidence:

```
mysql -h 192.168.1.20 -u root
Connected to MySQL 5.7.32

SHOW DATABASES;
+-----+
| Database |
+-----+
| coretech_main_db |
| coretech_users |
| coretech_payments |
+-----+
```

Impact:

- Full database access without authentication
- Customer payment data exposed
- User credentials accessible
- Potential for data manipulation/deletion
- PCI-DSS compliance violation

Affected Data:

- 2,847 user records
 - Payment transaction logs
 - Business-critical application data
-

Finding 3: SMBGhost Remote Code Execution (CVE-2020-0796)

Severity: CRITICAL **CVSS Score:** 9.8 **Host:** 192.168.1.30 **Port:** 445/tcp **Service:** SMBv3.1.1

Description: SMBv3.1.1 compression feature mein buffer overflow vulnerability hai jo remote code execution allow karti hai. Ye vulnerability wormable hai, matlab ek system se dusre system mein automatically spread ho sakti hai.

Evidence:

```
Nmap NSE Script:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in SMBv1
|       State: VULNERABLE
|_    Risk factor: HIGH  CVSSv2: 9.3 (HIGH)
```

Impact:

- Remote code execution as SYSTEM
 - Wormable (self-propagating)
 - Network-wide infection possible
 - Ransomware deployment vector
-

Finding 4: Apache Path Traversal (CVE-2021-41773)

Severity: HIGH **CVSS Score:** 7.5 **Host:** 192.168.1.10 **Port:** 80/tcp **Service:** Apache 2.4.41

Description: Apache HTTP Server 2.4.49 mein path normalization vulnerability hai jo attackers ko arbitrary files access karne deti hai. CGI scripts enabled hone par remote code execution bhi possible hai.

Evidence:

```
GET /cgi-bin/../../../../etc/passwd HTTP/1.1
Host: 192.168.1.10

Response:
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
```

Impact:

- Sensitive file disclosure
 - Potential for remote code execution
 - Server configuration exposure
 - Source code access
-

Finding 5: OpenSSH User Enumeration (CVE-2020-15778)

Severity: HIGH **CVSS Score:** 7.8 **Host:** 192.168.1.20 **Port:** 22/tcp **Service:** OpenSSH 8.2p1

Description: OpenSSH mein timing-based user enumeration vulnerability hai. Attacker valid usernames determine kar sakta hai by analyzing authentication response times.

Impact:

- Valid usernames discoverable
 - Enables targeted brute-force attacks
 - Information disclosure aiding further attacks
-

Finding 6: Weak Firewall Rules

Severity: HIGH **CVSS Score:** 7.2 **Host:** 192.168.1.1 (Firewall) **Port:** All

Description: Firewall configuration mein multiple weaknesses hain:

- RDP (3389) accessible from internal network to all hosts
- MySQL (3306) not segmented from web servers
- SMB (445) allowed across all VLANs
- No egress filtering rules implemented

Impact:

- Lateral movement facilitated
 - Attack surface expanded
 - Network segmentation ineffective
 - Data exfiltration possible
-

Finding 7: Missing Security Patches

Severity: MEDIUM **CVSS Score:** 6.4 **Host:** 192.168.1.30 **Port:** All

Description: Domain Controller par multiple security patches missing hain:

- Last patch date: March 2025 (15 months ago)
- 47 missing security updates
- Windows Update disabled

Impact:

- Multiple known vulnerabilities exploitable
 - Compliance violations
 - Increased attack surface
-

Finding 8: Outdated OpenSSL

Severity: MEDIUM CVSS Score: 5.9 Host: 192.168.1.10 Port: 443/tcp Service: OpenSSL 1.1.1k

Description: OpenSSL 1.1.1k vulnerable hai to denial of service through malformed ClientHello mes-
sages.

Impact:

- Service availability risk
- Potential for SSL/TLS disruption
- Man-in-the-middle attack facilitation

Risk Ratings

CVSS v3.1 Scoring

Severity Range	Count	Description
9.0 - 10.0	3	Critical - Immediate action required
7.0 - 8.9	5	High - Fix within 30 days
4.0 - 6.9	8	Medium - Fix within 60 days
0.1 - 3.9	4	Low - Fix within 90 days
0.0	6	Informational - Best practice

Risk Matrix

Likelihood / Impact	Insignificant	Minor	Moderate	Major	Catastrophic
Almost Certain	MEDIUM	HIGH	HIGH	CRITICAL	CRITICAL
Likely	MEDIUM	MEDIUM	HIGH	HIGH	CRITICAL
Possible	LOW	MEDIUM	MEDIUM	HIGH	HIGH
Unlikely	LOW	LOW	MEDIUM	MEDIUM	HIGH
Rare	LOW	LOW	LOW	MEDIUM	MEDIUM

Recommendations

Critical Priority (Fix within 7 Days)

R1: Patch BlueKeep (CVE-2019-0708) Action: Install Microsoft security update KB4499175
Steps:

1. Download patch from Microsoft Update Catalog
2. Test in staging environment
3. Install during maintenance window
4. Reboot server

5. Verify installation

Alternative: Disable RDP if not required

R2: Secure MySQL Database **Action:** Set strong root password and remove anonymous users
Steps:

1. Connect to MySQL as root
2. Remove anonymous users: `DELETE FROM mysql.user WHERE User=''`
3. Set root password: `ALTER USER 'root'@'localhost' IDENTIFIED BY 'strong_password'`
4. Create dedicated application user
5. Grant minimal privileges
6. Flush privileges

R3: Patch SMBGhost (CVE-2020-0796) **Action:** Install Microsoft security update KB4551762
Steps:

1. Download and install patch
2. Disable SMBv1 and SMBv2 if not needed
3. Enable SMB signing
4. Enable SMB encryption
5. Reboot server

High Priority (Fix within 30 Days)

R4: Implement Network Segmentation **Action:** Create separate VLANs with strict ACLs
Design:

- VLAN 10: Management (192.168.10.0/24)
- VLAN 20: DMZ (192.168.20.0/24)
- VLAN 30: Database (192.168.30.0/24)
- VLAN 40: Internal Users (192.168.40.0/24)
- VLAN 50: Guest (192.168.50.0/24)

R5: Harden Firewall Rules **Action:** Implement deny-by-default policy **Rules:**

- Block unnecessary inbound traffic
- Allow only required ports
- Implement source-based access control
- Enable egress filtering
- Log all denied connections

R6: Deploy Intrusion Detection **Action:** Install Snort/Suricata + Windows Defender ATP **Configuration:**

- Monitor all network traffic
- Alert on suspicious RDP/SMB activity
- Block known malicious IPs
- Integrate with SIEM

R7: Enable Multi-Factor Authentication **Action:** MFA for all administrative and remote access **Implementation:**

- Azure AD MFA for cloud services
- Duo Security for VPN
- TOTP for RDP via RD Gateway
- Hardware tokens for admin accounts

Medium Priority (Fix within 60 Days)

R8: Establish Patch Management **Action:** Implement WSUS + monthly patching **Components:**

- Windows Server Update Services (WSUS)
- Staging environment for testing
- Monthly patching window
- Emergency patching procedure
- Patch compliance reporting

R9: Upgrade Outdated Components **Action:** Upgrade all software to latest versions **Upgrades:**

- Apache: 2.4.41 -> 2.4.59+
- PHP: 7.4 -> 8.2+
- MySQL: 5.7.32 -> 8.0+
- OpenSSH: 8.2p1 -> 9.0+
- jQuery: 1.8.3 -> 3.7+
- Bootstrap: 3.3.7 -> 5.3+

R10: Deploy SIEM Solution **Action:** Implement centralized security monitoring **Options:**

- Splunk Enterprise Security
- Elastic Security (ELK Stack)
- Microsoft Sentinel
- QRadar

Configuration:

- Log collection from all devices

- Real-time alerting
- Dashboard for security metrics
- 1-year log retention

Low Priority (Fix within 90 Days)

R11: Security Awareness Training **Action:** Employee security training program **Topics:**

- Phishing identification
- Password security
- Social engineering awareness
- Incident reporting

R12: Quarterly Penetration Testing **Action:** Regular VAPT assessments **Schedule:**

- Quarterly external testing
- Bi-annual internal testing
- Annual red team exercise
- Continuous vulnerability scanning

R13: Incident Response Plan **Action:** Documented IR procedures **Components:**

- Incident classification matrix
- Response playbooks
- Communication templates
- Forensic readiness
- Backup and recovery procedures

Appendix

A. Testing Tools Used

Category	Tool	Version	Purpose
Scanning	Nmap	7.95	Network discovery, port scanning
Scanning	Nessus	10.7.1	Vulnerability assessment
Scanning	OpenVAS	22.4	Open-source vulnerability scanner
Exploitation	Metasploit	6.3.27	Exploit framework
Exploitation	Cobalt Strike	4.8	Advanced adversary simulation
Password	Hashcat	6.2.6	Password cracking

Table 3 – continued

Category	Tool	Version	Purpose
Password	Hydra	9.4	Online brute-forcing
Analysis	Wireshark	4.0.8	Network traffic analysis
Analysis	BloodHound	4.3.1	Active Directory analysis
Web	sqlmap	1.8.6	SQL injection automation

B. Testing Timeline

Date	Phase	Activities
June 15	Pre-Engagement	RoE signing, scope definition
June 16-17	Intelligence Gathering	OSINT, network discovery
June 18	Threat Modeling	Target prioritization
June 19-21	Vulnerability Analysis	Automated + manual testing
June 22-24	Exploitation	Controlled exploitation
June 25-26	Post-Exploitation	Impact assessment
June 27	Reporting	Documentation

C. Legal and Ethical Considerations

All testing was conducted with:

- Explicit written authorization from CoreTech Innovation management
- Defined scope and boundaries
- Emergency contact procedures
- No data exfiltration without permission
- Responsible disclosure of findings

Report Prepared By: Cyber Security Assessment Team **Date:** June 27, 2026 **Classification:** CONFIDENTIAL **Distribution:** CoreTech Innovation Management, IT Security Team

This report contains sensitive security information. Distribution is restricted to authorized personnel only.